
C Y B E R S E C U R I T Y A S S E S S M E N T

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target System: Metasploitable 2 | IP: 192.168.128.166
Assessment Type: Black-Box VAPT | Environment: Controlled Virtual Lab

PREPARED BY
Nithin Nayaka V N
1DA22AI023
AI&ML

REPORT DATE
May 2025
Version 1.0 — Final

C O N F I D E N T I A L — F O R A U T H O R I Z E D
R E V I E W O N L Y

Important Notice & Disclaimer

Scope of Assessment

This Vulnerability Assessment and Penetration Testing (VAPT) report was conducted exclusively within a controlled virtual lab environment using Metasploitable 2 as the target system. All activities were performed by Nithin Nayaka V N as part of an academic and professional internship exercise.

Legal Authorization

All testing activities were authorized, intentional, and conducted on systems owned and controlled by the assessor. Metasploitable 2 is an intentionally vulnerable virtual machine designed specifically for security training and testing purposes. No unauthorized systems were accessed during this assessment.

Confidentiality

This report is intended solely for the authorized recipient. The findings, methodologies, and technical details contained herein are confidential and must not be shared without explicit written permission.

Table of Contents

Important Notice & Disclaimer	2
Table of Contents.....	3
1. Executive Summary	4
2. Engagement Details.....	5
3. Assessment Methodology	6
4. Detailed Vulnerability Findings	7
4.1 Critical Severity Findings	7
4.2 High Severity Findings.....	9
4.3 Medium Severity Findings	9
5. Remediation Summary.....	11
6. Conclusion	12
7. Appendix.....	13
7.1 Glossary of Terms	13
7.2 References	13

1. Executive Summary

This report presents the findings of a comprehensive Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted against a Metasploitable 2 virtual machine. The assessment was structured across seven distinct phases, following industry-standard penetration testing methodologies including the PTES (Penetration Testing Execution Standard).

The assessment identified a total of 7 vulnerabilities across the target system, with 4 rated Critical severity. Successful exploitation of these vulnerabilities demonstrated unauthorized remote root access, arbitrary command execution, and exposure of sensitive system resources — all of which pose significant risk to any real-world equivalent environment.

Vulnerability Summary

Severity	Count	Risk Level
Critical	4	Critical
High	1	High
Medium	2	Medium
Low	0	Low

Key Findings at a Glance

- VSFTPD 2.3.4 backdoor allowed unauthenticated remote root access via a known backdoor trigger.
- Samba usermap_script vulnerability enabled arbitrary OS command execution without authentication.
- UnrealIRCd backdoor facilitated remote code execution through the IRC service.
- Default Telnet credentials (msfadmin/msfadmin) granted full administrative access to any user.
- Outdated Apache and PHP versions exposed the system to multiple known public exploits.
- Anonymous FTP access and HTTP TRACE method presented medium-severity information exposure risks.

Immediate action is strongly recommended to remediate all Critical and High severity findings before deploying any similar configuration in a production environment.

2. Engagement Details

The following table summarizes the key parameters of this engagement.

Project Name	Vulnerability Assessment and Penetration Testing (VAPT)
Target System	Metasploitable 2
Target IP Address	192.168.128.166
Testing Environment	Controlled Virtual Lab
Assessment Type	Black-Box Penetration Testing
Phases Covered	7 Phases (Reconnaissance through Post-Exploitation)
Methodology	PTES (Penetration Testing Execution Standard)
Assessor	Nithin Nayaka V N
Assessment Date	May 2025
Report Version	1.0 — Final
Classification	Confidential

3. Assessment Methodology

This engagement followed the Penetration Testing Execution Standard (PTES), structured into seven sequential phases. Each phase built upon the intelligence gathered in the previous, ensuring a thorough and systematic approach to identifying security weaknesses.

Phase	Name	Description
Phase 1	Reconnaissance	Passive and active information gathering about the target system using OSINT techniques and network discovery tools to map the attack surface without direct interaction with the target.
Phase 2	Scanning & Discovery	Active network scanning using tools such as Nmap to identify live hosts, open ports, running services, and operating system fingerprints.
Phase 3	Port Scanning	Detailed port enumeration across TCP and UDP ranges to identify all listening services, their version numbers, and associated banners.
Phase 4	Service Enumeration	In-depth service enumeration of discovered ports to identify specific software versions, configurations, and potential vulnerability indicators.
Phase 5	Vulnerability Assessment	Systematic identification of vulnerabilities using automated scanners (OpenVAS, Nessus) and manual review of discovered services against known CVE databases.
Phase 6	Exploitation	Controlled exploitation of identified vulnerabilities using the Metasploit Framework and manual techniques to demonstrate actual risk and impact.
Phase 7	Traffic Analysis & Post-Exploitation	Network traffic capture and analysis using Wireshark to observe exploitation traffic patterns, followed by post-exploitation activities to demonstrate the depth of access achievable.

Tools Used

Tool	Purpose	Tool	Purpose
Nmap	Port & Service Scanning	Metasploit Framework	Exploitation
Wireshark	Traffic Analysis	OpenVAS / Nessus	Vulnerability Scanning
Nikto	Web Server Scanning	Netcat	Shell Interaction
Enum4linux	SMB Enumeration	Hydra	Credential Testing

4. Detailed Vulnerability Findings

The following section details each identified vulnerability, including technical description, exploitation evidence, risk impact, and remediation guidance.

4.1 Critical Severity Findings

4.1.1. VSFTPD 2.3.4 Backdoor Vulnerability			• CRITICAL
CVSS Score	10.0 / 10	CVE Reference	CVE-2011-2523
Description VSFTPD version 2.3.4 contains a deliberately inserted backdoor in its source code. When a username containing the string ':' is supplied during authentication, the service opens a command shell on TCP port 6200, granting the attacker unauthenticated root-level access. This module was identified via banner grabbing during service enumeration.			
Impact An unauthenticated remote attacker can gain a root shell on the target system without any credentials. This allows complete system compromise, including full file system access, privilege escalation, lateral movement, and persistent backdoor installation.			
Evidence / Exploitation Metasploit module exploit/unix/ftp/vsftpd_234_backdoor was used. Upon sending a crafted username (':'), a root shell was received on port 6200. Commands such as whoami, id, and cat /etc/shadow were executed successfully, confirming root-level access.			
Recommendation Immediately remove VSFTPD 2.3.4 and upgrade to a current, vendor-supported FTP server version. Disable the FTP service entirely if not required. Implement firewall rules to restrict FTP access to trusted IP ranges only.			

4.1.2. Samba usermap_script Remote Code Execution			• CRITICAL
CVSS Score	10.0 / 10	CVE Reference	CVE-2007-2447
Description The Samba service running on the target was vulnerable to an OS command injection vulnerability via the 'username map script' configuration option. By sending a specially crafted username containing shell metacharacters during authentication, an attacker can inject and execute arbitrary OS commands with the privileges of the Samba daemon (root).			
Impact An unauthenticated remote attacker can execute arbitrary operating system commands as root. This provides complete system takeover, including the ability to read, write, and delete any files, create backdoor accounts, and pivot to other networked systems.			

Evidence / Exploitation

Metasploit module exploit/multi/samba/usermap_script was executed. A reverse root shell was obtained without any authentication. Commands confirmed root-level execution and full system control.

Recommendation

Update Samba to a patched version (3.0.26 or later) immediately. Disable the 'username map script' option in smb.conf. Restrict SMB ports (139, 445) at the firewall to trusted hosts only. Consider replacing legacy Samba deployments with modern alternatives.

4.1.3. UnreallRCd 3.2.8.1 Backdoor Remote Code Execution**• CRITICAL****CVSS Score**

10.0 / 10

CVE Reference

CVE-2010-2075

Description

UnreallRCd version 3.2.8.1 was distributed with a backdoor deliberately inserted into its source code. An attacker who sends a specially crafted string starting with 'AB' to the IRC service can execute arbitrary commands on the server with the privileges of the running IRC process.

Impact

Remote unauthenticated attackers can execute arbitrary OS commands with IRC daemon privileges. Depending on the daemon configuration, this may result in root-level access. The attacker can use this to deploy further payloads, harvest credentials, and maintain persistence.

Evidence / Exploitation

The Metasploit module exploit/unix/irc/unreal_ircd_3281_backdoor was used. A command shell was obtained via the backdoored IRC service, confirming remote code execution. System information commands were run successfully from the obtained shell.

Recommendation

Immediately remove UnreallRCd 3.2.8.1 from the system. If an IRC service is required, replace with a current, maintained IRC daemon. Apply OS-level restrictions to limit the privileges of any service daemon. Block unnecessary IRC ports (6660-6669) at the perimeter firewall.

4.1.4. Default Credentials — Telnet Service**• CRITICAL****CVSS Score**

9.8 / 10

CVE Reference

CWE-1392

Description

The Telnet service was found running on the standard port 23 and accepting authentication using the default credentials msfadmin/msfadmin. Telnet is an inherently insecure protocol that transmits all data, including usernames and passwords, in cleartext over the network.

Impact

Any user with network access can authenticate to the system using the known default credentials, gaining a fully functional administrative shell. Additionally, Telnet's cleartext transmission means credentials and session data can be intercepted by any observer on the network path.

Evidence / Exploitation

Telnet service authentication was successfully tested using the default credentials `msfadmin:msfadmin`. Full interactive shell access was obtained. Network traffic analysis using Wireshark confirmed that the username, password, and all session commands were transmitted in plaintext and were readable in the captured packets.

Recommendation

Disable the Telnet service immediately. Replace Telnet with SSH for all remote access requirements. Enforce strong, unique password policies. Implement an account lockout policy after repeated failed authentication attempts. Remove all default accounts and credentials.

4.2 High Severity Findings

4.2.1. Outdated Apache HTTP Server and PHP

• HIGH**CVSS Score**

7.5 / 10

CVE Reference

Multiple CVEs

Description

The web server was found running Apache HTTP Server version 2.2.8 and PHP version 5.2.4. Both versions are end-of-life and no longer receive security patches. Multiple known critical and high-severity vulnerabilities exist for these versions in public CVE databases.

Impact

Attackers can leverage publicly available exploits targeting known vulnerabilities in these outdated software versions to achieve remote code execution, denial of service, information disclosure, or privilege escalation on the web server.

Evidence / Exploitation

Version banners were captured via HTTP response headers and Nmap service version detection. Cross-referencing with the National Vulnerability Database (NVD) confirmed numerous unpatched CVEs against these versions, including remote code execution vulnerabilities.

Recommendation

Upgrade Apache HTTP Server to the current stable release and PHP to the latest supported version (8.x). Implement a patch management process to ensure all server software is kept current. Disable version disclosure in server headers by setting `ServerTokens Prod` and `expose_php = Off`.

4.3 Medium Severity Findings

4.3.1. Anonymous FTP Access Enabled

• MEDIUM**CVSS Score**

5.3 / 10

CVE Reference

CWE-284

Description

The FTP service was configured to permit anonymous login, allowing any unauthenticated user to connect to the FTP server and access publicly exposed files and directories. This was identified during service enumeration.

Impact

Sensitive files stored on the FTP server may be accessible to unauthorized users. Anonymous access can also allow attackers to use the FTP server for reconnaissance, understanding the directory structure and file naming conventions of the target organization.

Evidence / Exploitation

FTP connection using the anonymous username was successful with any password. Directory listing was obtained, revealing accessible files on the server.

Recommendation

Disable anonymous FTP access in the VSFTPD configuration by setting `anonymous_enable=NO`. If file sharing is required, use SFTP (SSH File Transfer Protocol) instead, which provides encrypted transport and strong authentication.

4.3.2. HTTP TRACE Method Enabled

• MEDIUM

CVSS Score

5.3 / 10

CVE Reference

CWE-16

Description

The web server was found to have the HTTP TRACE method enabled. This method, intended for diagnostic use, echoes back the full request received by the server including HTTP headers. This can be exploited in Cross-Site Tracing (XST) attacks in combination with Cross-Site Scripting.

Impact

An attacker can potentially exploit the TRACE method in conjunction with other browser-level vulnerabilities to steal session cookies and authentication tokens, even when the `HttpOnly` flag is set on cookies, bypassing some XSS mitigations.

Evidence / Exploitation

An HTTP TRACE request was sent to the target web server using curl. The server returned a 200 OK response and echoed the full request headers, including any custom headers injected in the request, confirming the method is active.

Recommendation

Disable the HTTP TRACE method in the Apache configuration by adding `TraceEnable Off` to `httpd.conf`. Verify the setting is applied and restart the web service. Ensure the configuration persists across server restarts.

5. Remediation Summary

The following table consolidates all remediation actions organized by priority. Immediate actions should be completed within 24-48 hours. Short-term actions within 30 days. Ongoing practices should be embedded into standard operations.

Priority	Remediation Action	Relates To
Immediate	Remove VSFTPD 2.3.4 and all services with known backdoors	Critical
Immediate	Patch or replace vulnerable Samba installation	Critical
Immediate	Remove UnrealIRCd and all legacy IRC services	Critical
Immediate	Disable Telnet, replace with SSH, change all default credentials	Critical
Short-term	Upgrade Apache and PHP to current supported versions	High
Short-term	Disable anonymous FTP access	Medium
Short-term	Disable HTTP TRACE method on web server	Medium
Ongoing	Implement patch management process for all services	Best Practice
Ongoing	Enforce strong password and account lockout policies	Best Practice
Ongoing	Deploy network segmentation and firewall rules for all services	Best Practice
Ongoing	Implement continuous vulnerability scanning and monitoring	Best Practice

6. Conclusion

This assessment successfully demonstrated a complete penetration testing lifecycle — from initial reconnaissance through exploitation and post-exploitation analysis — against the Metasploitable 2 target system within a controlled virtual lab environment.

A total of 7 vulnerabilities were identified and validated: 4 Critical, 1 High, and 2 Medium severity. The critical findings — VSFTPD backdoor, Samba usermap_script, UnrealIRCd backdoor, and default Telnet credentials — all resulted in successful remote root access during the exploitation phase, representing a complete compromise of the target system.

The findings underline three core security failure patterns that are common across real-world environments:

- Running unpatched or end-of-life software with known public exploits.
- Retaining default credentials and unnecessary services in the deployed configuration.
- Absence of network-level controls to restrict access to sensitive service ports.

This project demonstrated practical proficiency in professional vulnerability assessment methodology, service enumeration, vulnerability exploitation using industry-standard tools, traffic analysis, and formal security reporting — skills directly applicable to a cybersecurity analyst or penetration tester role.

7. Appendix

7.1 Glossary of Terms

Term	Definition
VAPT	Vulnerability Assessment and Penetration Testing — a security evaluation combining systematic vulnerability identification with active exploitation testing.
CVE	Common Vulnerabilities and Exposures — a standardized reference system for publicly known cybersecurity vulnerabilities.
CVSS	Common Vulnerability Scoring System — a framework for rating the severity of security vulnerabilities on a 0–10 scale.
PTES	Penetration Testing Execution Standard — an industry methodology framework defining phases and best practices for penetration testing.
Backdoor	A covert method of bypassing normal authentication or encryption in a system, often inserted maliciously.
RCE	Remote Code Execution — a class of vulnerability allowing an attacker to run arbitrary code on a remote system.
SMB	Server Message Block — a network protocol used for sharing files, printers, and other resources between nodes.
Metasploit	An open-source penetration testing framework providing tools and exploits for vulnerability validation.
Shell	A command-line interface providing access to an operating system; a 'root shell' provides the highest privilege level.
CWE	Common Weakness Enumeration — a community-developed list of common software and hardware security weaknesses.

7.2 References

1. National Vulnerability Database (NVD) — <https://nvd.nist.gov>
2. CVE-2011-2523: VSFTPD 2.3.4 Backdoor — <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523>
3. CVE-2007-2447: Samba usermap_script — <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-2447>
4. CVE-2010-2075: UnreallIRCd Backdoor — <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2010-2075>
5. Penetration Testing Execution Standard (PTES) — <http://www.pentest-standard.org>
6. OWASP Testing Guide — <https://owasp.org/www-project-web-security-testing-guide/>
7. Metasploit Framework Documentation — <https://docs.metasploit.com>